# Fuzzing Guiado por Contrato para APIs REST

***Title: Contract-Guided Fuzzing for REST APIs***

**Levi da Rosa Gomes (aluno)[1], Fábio Austrian Zanin (orientador)[1]**

[1] Universidade Regional Integrada do Alto Uruguai e das Missões
Departamento de Engenharias e Ciência da Computação
Caixa Postal 743 – 99.709-910 – Erechim – RS – Brasil

103495@uricer.edu.br, faz@uricer.edu.br

***Abstract.*** *This work presents a contract-guided fuzzing approach for REST APIs.*
***Keywords*** *Word 1, Word 2, Word 3, Word 4, Word 5.*

***Resumo.*** *Este trabalho apresenta uma abordagem de fuzzing guiado por contrato para APIs REST.*
***Palavras-Chave*** *Palavra 1, Palavra 2, Palavra 3, Palavra 4, Palavra 5.*

## 1. Introdução

APIs REST tornaram-se parte essencial da infraestrutura de sistemas modernos, conectando serviços, aplicações web e dispositivos móveis [Arcuri et al. 2026]. Nesse cenário, falhas de robustez e inconsistências entre o comportamento da API e o contrato publicado impactam diretamente a confiabilidade de integrações e o custo de manutenção. Embora testes funcionais tradicionais sejam eficazes para validar cenários felizes (happy path), eles frequentemente deixam de exercitar valores-limite, formatos inválidos e combinações pouco usuais de parâmetros, que são justamente as situações em que falhas sutis tendem a se manifestar.

O uso de contratos formais, como a especificação OpenAPI (versões 3.0 e 3.1), viabiliza uma abordagem "guiada por contrato"para a geração de casos de teste: em vez de produzir entradas aleatórias, o processo explora estruturas, tipos e restrições descritas no schema para produzir mutações *válidas e inválidas* de forma sistemática. Essa estratégia aumenta a probabilidade de revelar respostas inesperadas (por exemplo, códigos 5xx, mensagens de erro inconsistentes ou divergências estruturais entre a resposta e o contrato) sem exigir acesso ao código-fonte nem instrumentação interna da aplicação, isto é, em um contexto *black-box* [Meyer 1992].

Este trabalho propõe o desenvolvimento e a avaliação de uma ferramenta de *fuzzing* automatizado para APIs REST baseada exclusivamente em contratos OpenAPI. A ferramenta implementa: (i) um parser capaz de extrair e interpretar parâmetros, corpos de requisição e restrições declaradas no contrato; (ii) um motor de mutações que gera sistematicamente casos de teste dirigidos por tipos e *constraints* (por exemplo, tamanhos mínimos e máximos, enumerações, formatação e obrigatoriedade); (iii) um orquestrador e um executor de requisições com suporte à concorrência; e (iv) um analisador que registra evidências e classifica comportamentos anômalos à luz do contrato. Além disso, o estudo inclui uma comparação exploratória entre o *fuzzing* guiado pelo contrato e uma linha de base não guiada, com o objetivo de discutir ganhos e limitações práticos da abordagem.

O escopo delimita-se a APIs REST descritas em OpenAPI, não abrangendo cenários dependentes de sequenciamento complexo de requisições ou manutenção de estado entre chamadas, autenticação avançada (por exemplo, fluxos completos de OAuth2) nem avaliação de carga ou desempenho. Em contrapartida, busca-se integrá-la de forma simples a fluxos de integração contínua (CI), reduzindo o custo de adoção e favorecendo a detecção antecipada de inconsistências durante o ciclo de desenvolvimento.

## 2. Problema, Justificativa e Escopo

Descreva o problema, a justificativa e o escopo do trabalho (placeholder).

## 3. Objetivos

### 3.1. Objetivo Geral

Descreva o objetivo geral (placeholder).

### 3.2. Objetivos Específicos

Liste os objetivos específicos (placeholder).

## 4. Referencial Teórico

Apresente conceitos e base teórica relevante (placeholder).

## 5. Trabalhos Relacionados

Resuma pesquisas e soluções correlatas (placeholder).

## 6. Metodologia

Descreva métodos, etapas e ferramentas a serem utilizadas (placeholder).

## 7. Planejamento e Cronograma

Apresente fases, marcos e cronograma (placeholder).

## 8. Resultados Esperados e Entregáveis

Liste resultados e entregas esperados (placeholder).

## 9. Considerações Finais

Síntese do projeto e próximos passos (placeholder).

## 10. References

## Referências

Arcuri, A., Poth, A., Rrjolli, O., Garrett, P., e Galeotti, J. P. (2026). Fuzzing rest apis in industry: Necessary features and open problems.

Meyer, B. (1992). Applying "design by contract". *IEEE Computer*, 25(10):40–51.